

Main problems Codex found

1. Security is the biggest issue

- You have **hardcoded secrets and credentials** in tracked files.
- This includes mail password, API keys, Google key, URA key in application-local.yml.
- Your **JWT secret is also hardcoded** in JwtUtil.java.
- These should not be in the repo at all. They should be moved to env vars or secret management.

2. OTP verification looks unsafe

- In AuthService, OTP expiry does **not seem to be enforced properly** during verify.
- Right now it looks like the code mainly checks whether the OTP matches, but may still allow an expired OTP through.
- That is a logic bug in auth flow.

3. Reset password has a schema mistake

- In ResetLink.java, the DB index references the wrong column name.
- It uses OTPtoken even though the actual field is token.
- That can cause schema/runtime problems.

4. Backend testability is weak right now

- Maven wrapper is broken in this environment, so backend tests could not be run.
- That means build confidence is lower because Codex could not verify backend using the wrapper.

5. Booking API contract is inconsistent

- Frontend sends startTime and endTime.
- Backend CreateBookingRequest only accepts evChargingPointId.
- So frontend and backend are not aligned. This is a correctness / maintenance problem.

6. Booking logic has some messy parts

- BookingService.create() seems to set endTime(now) immediately and duplicates startTime(now).
- It also uses IllegalArgumentException / IllegalStateException in API flow, which may turn into 500 errors if not handled cleanly.
- So the EV booking flow may have reliability issues.

7. Frontend quality checks are not fully clean

- tsc --noEmit passes, which is good.
- But npm run lint fails with 1 error and 8 warnings.
- There is an apostrophe error in transactions.tsx, plus hook dependency / unused variable warnings in profile.tsx.

8. Frontend still has hardcoded config / dev artifacts

- Hardcoded backend URL in frontend config
- Hardcoded LTA key
- Dev reset button still present in login page

- These are not ideal for portability or security.

9. Maintainability is becoming a problem

- Your main tab screen index.tsx is 946 lines long.
- evMain.tsx uses multiple any types.
- This makes the project harder to maintain and refactor later.

Codex's main suggestions

- Move all secrets to env vars and rotate exposed keys
- Fix OTP expiry enforcement
- Fix the ResetLink index column mismatch
- Align booking payload between frontend and backend
- Replace generic exceptions with explicit API-safe exceptions
- Repair Maven wrapper
- Clean lint issues and remove debug/dev UI
- Split up index.tsx into smaller hooks/components
- Replace any with proper typed DTOs/interfaces
- Centralize config instead of hardcoding URLs/keys everywhere

Reflection:

3.3.2: Claude managed to reconstruct every AuthService controller class perfectly just from the black box test cases (equivalence and boundary value) and some brief descriptions of each class. It actually ended up writing cleaner code than I did. -KQ

3.3.3: I feel that Codex is able to spot many of the easily overlooked mistakes and bad practices. However it may not understand the context of why some code was actually purposefully hardcoded for now as we are still in the prototyping and developing stage. I also found it helpful that the critique prioritised issues by severity, because it made it clearer which problems are urgent and which are more about cleanup or refactoring. -Ryan